PrestArte

Ficha técnica · Octubre de 2026

DOCUMENTO PARA LA REVISIÓN TÉCNICA

Ficha técnica de PrestArte

Arquitectura, modelo de datos, API, seguridad, estado de validación y deuda técnica conocida. Complementa al dosier de producto.

Arquitectura



Arquitectura cliente-servidor desacoplada. Toda la lógica de negocio y la validación definitiva viven en el backend; el frontend valida además en el cliente para mejorar la experiencia. El backend envía correos por SMTP y genera PDF en el servidor. Una tarea programada diaria envía los recordatorios.

Stack y versiones

COMPONENTE	TECNOLOGÍA	VERSIÓN
Lenguaje backend	Java (LTS)	21
Framework backend	Spring Boot: Web MVC, Security, Data JPA, Validation, Mail	4.0.2
Tokens	JJWT	0.12.6
PDF	OpenPDF (LibrePDF)	1.3.30
Base de datos	MySQL (probado también con MariaDB 10.11)	8.x
Framework frontend	Angular: componentes standalone, signals, carga diferida	21.2
Estilos	Tailwind CSS	4.x
Lenguaje frontend	TypeScript	5.9
Construcción	Maven (wrapper incluido) y Angular CLI / npm	—

Todas las dependencias son de código abierto con licencias permisivas (Apache 2.0, MIT, LGPL/MPL en OpenPDF). No hay costes de licencia.

Tamaño del código

167
ficheros Java · 12.844 líneas

14.679
líneas TS, HTML y SCSS

102
endpoints REST en 17 controladores

31
entidades JPA y enumerados

BACKEND

Organización del código

PAQUETE	CONTENIDO
`controller`	17 controladores REST delgados que delegan en servicios: autenticación, obras, préstamos, envíos, exposiciones, informes de instalaciones, procedencia, chat y mensajes, avisos, valoraciones, archivos, paneles y transportistas.
`service`	27 servicios transaccionales con la lógica de negocio: préstamos, envíos, seguro y permisos (`LoanDocumentsService`), supervisión del correo, informes de estado, compatibilidad, estimación de costes y CO_2, procedencia, recordatorios, PDF, email y validación de subidas.
`service.statemachine`	`LoanStateMachine` y `ShipmentStateMachine` : mapas de transiciones permitidas. Una transición inválida devuelve HTTP 409.
`model.entity` / `dto`	Entidades JPA (usuarios con herencia JOINED) y DTO de entrada y salida con Bean Validation.
`repository`	24 repositorios Spring Data, con `@EntityGraph` donde hace falta carga anticipada.
`security`	Filtro JWT, usuario actual, `RateLimitFilter` y carga de usuarios.
`config`	Seguridad y CORS, programación de tareas, administrador inicial y datos de demostración.
`exception`	`GlobalExceptionHandler` : respuestas de error uniformes (400, 401, 403, 404, 409).

Ciclo de vida del préstamo (14 estados)

`REQUESTED` → `ACCEPTED` → `QUOTE_PENDING` ⇄ `QUOTE_PROPOSED` → `PAID` → `READY_FOR_PICKUP` → `IN_TRANSIT` → `DELIVERED` → `ON_LOAN` → `RETURNING` → `RETURNED`

Estados finales alternativos: `REJECTED` (desde la solicitud) y `CANCELLED` (hasta que la obra sale). Un presupuesto rechazado vuelve a `QUOTE_PENDING` y permite reasignar transportista.

Ciclo de vida del envío (7 estados)

`REQUESTED` → `QUOTED` → `APPROVED` → `PICKED_UP` → `IN_TRANSIT` → `DELIVERED` · `REJECTED`

Cada préstamo tiene un envío de ida y otro de vuelta. Los envíos notifican al préstamo cuando avanzan, de modo que ambos nunca quedan incoherentes.

Reglas de negocio destacadas

- La obra no puede pasar a «lista para recoger» ni recogerse sin seguro aprobado que cubra el valor y el periodo, ni sin permiso de exportación cuando la Ley 16/1985 lo exige.
- Al aceptar una solicitud se rechazan de forma automática las solicitudes que se solapan, con aviso a esas instituciones.
- Las ampliaciones comprueban reservas posteriores, la fecha límite del permiso y la cobertura del seguro.
- La recogida y la entrega exigen un informe de estado con fotografías; la entrega la confirma quien recibe la obra.
- Sin declaración de titularidad firmada, una obra no recibe solicitudes. Las obras marcadas como sospechosas en la diligencia debida salen del catálogo.

DATOS Y API

Modelo de datos

ÁREA	ENTIDADES
Usuarios	User (herencia JOINED) → Admin, Collector, Foundation, TransportCompany · CoverageArea · PasswordResetToken
Obras	Artwork · ArtworkFile · LoanRequirements · ImageRights · ProvenanceEntry · DueDiligenceCheck
Préstamos	LoanRequest · LoanEvent · Exhibition · FacilityReport · InsuranceCertificate · ExportPermit · Review
Logística	Shipment · ConditionReport · SupervisionCheckpoint · CourierMode
Comunicación	ChatSession · Message · Notification · ReminderLog
Archivos	DBFile (contenido binario con identificador UUID)

API REST

102 endpoints bajo `/api` : 49 GET, 42 POST, 5 PUT, 5 DELETE y 1 PATCH. Los públicos son el catálogo, la disponibilidad y el historial de exposiciones de las obras, el directorio de transportistas, las valoraciones agregadas y la autenticación. El resto exige JWT y el rol y la relación con el recurso adecuados.

GRUPO	EJEMPLOS
Autenticación	`POST /auth/register` (multipart con documento) · `/auth/login` · `/auth/forgot-password` · `/auth/reset-password`
Obras	`GET /artworks/search` · `/artworks/{id}/availability` · `/artworks/{id}/cost-estimate` · `/artworks/{id}/compatibility` · `/artworks/{id}/provenance`
Préstamos	`POST /loan-requests` · `/{id}/accept` · `/{id}/insurance` · `/{id}/export-permit` · `/{id}/ready-for-pickup` · `/{id}/start-return` · `/{id}/extension` · `/{id}/contract`
Envíos	`POST /shipments/{id}/quote` · `/approve-quote` · `/picked-up` · `/in-transit` · `/delivered`
Instituciones	`/exhibitions` · `/facility-report`
Comunicación	`/chat-sessions` · `/messages` · `/notifications` · `/loan-requests/{id}/reviews`
Administración	Aprobación de cuentas · `/admin/due-diligence/pending` · `/admin/artworks/{id}/due-diligence`

Frontend

Organizado en `core` (servicios HTTP, modelos espejo de los DTO, guards de autenticación y rol, interceptores JWT y de errores, validadores de DNI, NIE, CIF y teléfono), `features` (una carpeta por pantalla y por perfil) y `shared` (componentes reutilizables: estado, tarjetas de cifras, panel de compatibilidad, estimación de costes, condiciones del prestador). El pipe `secureFile` descarga los archivos protegidos con el token.

Seguridad y privacidad

MEDIDA	DETALLE
Autenticación	JWT firmado, sin sesión en el servidor. Contraseñas con BCrypt.
Autorización	Rol por ruta y comprobación de propiedad en cada operación: solo el dueño edita su obra y solo las partes de un préstamo lo ven o escriben en su chat.
Verificación de cuentas	Alta con documento acreditativo; la cuenta queda pendiente hasta que la administración la aprueba. Validación de la letra o el dígito de control de DNI, NIE y CIF.
Archivos	Descarga con permisos según a qué pertenece el archivo. Tipo detectado por el contenido real (JPEG, PNG, WEBP, PDF), no por la extensión. Cabecera `Content-Security-Policy: sandbox`.
Límite de intentos	Por IP en login (10 cada 5 min), registro (5 por hora) y recuperación de contraseña. Respuesta 429.
Recuperación de contraseña	Token de un solo uso. La respuesta no revela si el email está registrado.
Producción	Perfil `prod` sin valores por defecto: base de datos, correo, secreto JWT, CORS y URL del frontend son obligatorios por variable de entorno. Datos de demostración desactivados y trazas de error ocultas.
Privacidad del coleccionista	Anonimato por defecto, valor en horquilla para terceros, dirección de recogida solo para el transportista con envío en curso, documentos confidenciales.

Validación realizada (23 de octubre de 2026)

- **Compilación:** `mvn compile` correcto con OpenJDK 21 (269 clases generadas).
- **Arranque:** la aplicación arranca contra MariaDB 10.11, crea el esquema y siembra el administrador y los datos de demostración.
- **Prueba de extremo a extremo por API** con los tres perfiles: alta de 4 obras con fotos, exposición, estimación de coste, 3 solicitudes, aceptación, presupuesto, aprobación, contrato PDF, seguro subido y aprobado, recogida con informe y fotos, tránsito, entrega, estado `ON_LOAN`, certificado de exposición, devolución completa hasta `RETURNED`, valoraciones e historial con 16 eventos. Todos los pasos respondieron correctamente.
- **Frontend:** servido con Angular CLI y recorrido con los cuatro perfiles; las capturas del dosier proceden de esa sesión.

Requisitos de despliegue

Java 21, MySQL 8, un servidor SMTP y un servidor web estático para el frontend compilado. En el entorno de desarrollo se usó un portátil estándar; para un primer despliegue basta un VPS de 2 vCPU y 4 GB de RAM.

DEUDA TÉCNICA

Deuda técnica conocida y recomendaciones

Lista transparente de lo que un equipo debería abordar antes o poco después del lanzamiento. Ninguno de estos puntos bloquea el funcionamiento actual.

PUNTO	SITUACIÓN	RECOMENDACIÓN	PRIORIDAD
Tests automáticos	Solo existe el test de arranque. La validación se ha hecho con una prueba de extremo a extremo manual por API.	Tests unitarios de máquinas de estados y servicios, y tests de integración del flujo del préstamo.	Alta
Migraciones	Esquema gestionado con `ddl-auto=update`.	Flyway con un script base generado del esquema actual.	Alta
Despliegue	Sin Docker ni integración continua.	Dockerfile para cada parte, docker-compose y un pipeline de CI.	Alta
Textos legales	Pendientes privacidad (RGPD), cookies y aviso legal.	Redacción con asesoría legal; registro de actividades de tratamiento.	Alta
Almacenamiento de archivos	Archivos en la base de datos (LONGBLOB).	Migrar a almacenamiento de objetos compatible con S3.	Media
Búsqueda del catálogo	Los filtros se aplican en memoria.	Consultas JPA o Specifications cuando el catálogo crezca.	Media
Estimador de costes	Tarifas de referencia razonables pero no calibradas con datos de mercado; cada estimación lista sus supuestos.	Calibrar con presupuestos reales de transportistas.	Media
Avisos en tiempo real	Consulta periódica desde el frontend.	WebSockets o Server-Sent Events.	Baja
Pagos	El paso «Pagado» se marca al aprobar el presupuesto; no hay cobro real.	Pasarela de pago y modelo de comisión.	Según modelo
Errores de entrada	Un JSON mal formado responde 500 en lugar de 400.	Añadir el caso al manejador global de excepciones.	Baja
Idiomas	Interfaz solo en español.	Internacionalización de Angular, empezando por el inglés.	Baja

Documentación disponible

- **README.md**: descripción funcional, perfiles, flujo, seguridad, stack y estructura.
- **CHANGELOG.md**: detalle de la última fase de desarrollo, incluidos los cambios de API.
- **Memoria del proyecto** (Word): análisis, diagramas de clases, casos de uso, flujos, máquinas de estado, esquema de base de datos, manual de instalación y manual de usuario.
- **Carpeta design/**: prototipos de las pantallas.